# CRISC Domain B – Impossible Questions

## 100 Expert-Level Questions – Answer on the Next Slide

CRISC Mastery Series

October 21, 2026

# Warning

**Extreme Difficulty**

100 questions. Each answer and explanation is on the slide after its question.
What remains needs calculation, probability, dependency analysis and judgment.
Do not be discouraged if you miss most of them.

# Outline


1. Quantitative Risk Analysis
2. Risk Evaluation
3. Business Impact Analysis
4. Risk Treatment
5. Risk Monitoring
6. Advanced Quantitative Analysis
7. Advanced Risk Evaluation
8. Advanced Business Impact and Recovery
9. Advanced Risk Treatment
10. Advanced Risk Monitoring
11. Advanced Identification and Governance

# Q1: Control ROI

## Question

An asset is worth $2M with an exposure factor of 40% and an ARO of 0.5. A control reduces the ARO to 0.1 and the exposure factor to 25% at a cost of $60K per year. What is the net annual benefit?

- A $350K
- B $410K
- C $290K
- D $50K

# Q1: Explanation

## Correct Answer: C

- Before: ALE = \$2M × 40% × 0.5 = \$400K
- After: ALE = \$2M × 25% × 0.1 = \$50K
- Gross reduction = \$350K
- Net benefit = \$350K − \$60K = \$290K

## Critical Trap

\$350K ignores the control cost. \$50K is the residual ALE, not a benefit.

# Q2: Joint Probability Bounds

## Question

Risk A has a 20% likelihood and Risk B has a 30% likelihood. They are known to be positively correlated. Which statement MUST be true about the probability that both occur?

- A. It equals exactly 6%
- B. It is at least 50%
- C. It can exceed 30%
- D. It is strictly greater than 6% and at most 20%

# Q2: Explanation

## Correct Answer: D

- Independence gives $0.2 \times 0.3 = 6\%$
- Positive correlation pushes the joint probability above 6%
- A joint event can never be more likely than its rarer component
- Upper bound $= \min(20\%, 30\%) = 20\%$

## Critical Trap

Correlation changes the joint probability, but it is always capped by the least likely event.

# Q3: Annualizing a Monthly Probability

## Question

A threat event occurs in any given month with probability 5%, independently of other months. What is the probability of at least one occurrence in 12 months?

- (A) About 46%
- (B) About 54%
- (C) 5%
- (D) 60%

# Q3: Explanation

## Correct Answer: A

- $P(\text{none in 12 months}) = 0.95^{12} \approx 0.54$
- $P(\text{at least one}) = 1 - 0.54 \approx 0.46$
- 54% is the probability of NO event
- $12 \times 5\% = 60\%$ ignores overlap of outcomes

## Critical Trap

Probabilities of "at least one" do not add linearly. Use the complement.

# Q4: Alert Reliability

## Question

The probability of a targeted attack this quarter is 10%. When an attack is under way, the detection alert fires 90% of the time. When no attack is under way, it fires falsely 20% of the time. The alert has just fired. What is the probability that an attack is actually under way?

A. 90%
B. 10%
C. About 33%
D. 50%

# Q4: Explanation

## Correct Answer: C

- $P(\text{alert}) = 0.9 \times 0.1 + 0.2 \times 0.9 = 0.27$
- $P(\text{attack} \mid \text{alert}) = 0.09/0.27 = 1/3$
- A low base rate makes most alerts false positives
- The alert raises the estimate from 10% to 33%, not to 90%

## Critical Trap

Detection accuracy is not the same as the probability that an alert is real. Base rates matter.

# Q5: Three-Point Estimate

## Question

Analysts estimate a loss at $100K (optimistic), $200K (most likely) and $700K (pessimistic). What is the PERT expected loss?

- A $333K
- B $200K
- C $267K
- D $400K

# Q5: Explanation

## Correct Answer: C

- PERT mean $= (O + 4M + P)/6$
- $= (100 + 800 + 700)/6 \approx \$267K$
- \$333K is the simple average of the three values
- \$200K is the mode and ignores the long tail

## Critical Trap

The most likely value is not the expected value when the distribution is skewed.

# Q6: Skewed Confidence Interval

## Question

A FAIR analysis gives a 90% confidence interval of $200K to $2M with a most likely value of $500K. Which interpretation is BEST?

A. Expected annual loss likely exceeds $500K because of right skew
B. Expected annual loss is exactly $500K
C. The interval is invalid because it is asymmetric
D. The loss will certainly fall inside the interval

# Q6: Explanation

## Correct Answer: A

- Loss distributions are typically right-skewed (lognormal-like)
- The long upper tail pulls the mean above the mode
- Budgeting on the mode understates expected loss
- A 90% interval leaves a 10% chance of falling outside it

## Critical Trap

Most likely $\neq$ expected value. Asymmetric intervals are normal for losses.

# Q7: Aggregating Volatility

## Question

Two risks each have an annual loss standard deviation of $300K. Their correlation is 0.5. What is the standard deviation of the combined loss?

- (A) $424K
- (B) $300K
- (C) $600K
- (D) $520K

# Q7: Explanation

## Correct Answer: D

- Var $= \sigma^2 + \sigma^2 + 2\rho\sigma^2 = 3\sigma^2$
- SD $= 300 \times \sqrt{3} \approx \$520K$
- \$424K assumes independence ($\rho = 0$)
- \$600K assumes perfect correlation ($\rho = 1$)

## Critical Trap

Standard deviations do not add. Correlation controls how much diversification you get.

# Q8: Common-Cause Failure

## Question

Two preventive controls each stop an attack 90% of the time. A design review calls them "independent layers," implying a 1% chance that both fail. Testing reveals a shared dependency (the same identity provider) whose failure disables both controls 4% of the time. Otherwise they fail independently. What is the probability that both fail?

- A 1%
- B 4%
- C About 5%
- D 10%

# Q8: Explanation

## Correct Answer: C

- $P(\text{both fail}) = 0.04 + 0.96 \times 0.10 \times 0.10$
- $= 0.04 + 0.0096 \approx 4.96\%$
- Residual risk is about five times the "independent" estimate
- Defense in depth fails when layers share a failure mode

## Critical Trap

Layered controls are only independent if they share no common dependency.

# Q9: Rule of Three

## Question

A control is tested 30 times with zero failures. Which statement about its true failure rate is MOST defensible?

- A. It is 0%
- B. It is at most 3%
- C. It is at most 30%
- D. It is at most roughly 10% with 95% confidence

# Q9: Explanation

## Correct Answer: D

- With zero failures in $n$ trials, the 95% upper bound is about $3/n$
- $3/30 = 10\%$
- Zero observed failures does not prove zero failures
- Small samples leave wide uncertainty

## Critical Trap

"No failures observed" is not "no failures exist."

# Q10: FAIR Decomposition

## Question

Threat event frequency is 20 per year and vulnerability (probability a threat event becomes a loss event) is 15%. Primary loss per event is $40K. There is a 30% chance of a secondary loss of $200K per event. What is the annualized loss exposure?

- A $120K
- B $720K
- C $300K
- D $2.0M

# Q10: Explanation

## Correct Answer: C

- Loss event frequency $= 20 \times 15\% = 3$ per year
- Expected loss per event $= 40K + 0.3 \times 200K = \$100K$
- ALE $= 3 \times \$100K = \$300K$
- \$120K ignores secondary loss; \$720K treats it as certain; \$2.0M ignores vulnerability

## Critical Trap

Use loss event frequency, not threat event frequency, and weight secondary loss by its probability.

# Q11: Ordinal Matrix Flaw

## Question

An organization multiplies 1–5 likelihood and impact scores in a 5x5 matrix. A risk scored 5x1 and a risk scored 1x5 both receive 5. What is the MOST fundamental flaw in this approach?

- **A** Multiplication always overstates risk
- **B** Ordinal ranks are not ratio-scale values, so products can misrank risks with very different expected losses
- **C** A 5x5 matrix is too small
- **D** Scores above 20 cannot be compared

# Q11: Explanation

## Correct Answer: B

- Scale points are ordered labels, not measured quantities
- Equal products can hide very different loss profiles
- Products of ordinal ranks can reverse true priority
- Calibrated quantitative ranges are more defensible

## Critical Trap

A numeric-looking score does not make an ordinal scale quantitative.

# Q12: Aggregate Appetite and Correlation

## Question

Three risks each have an expected annual loss of $400K. Aggregate appetite is $1M and aggregate tolerance is $1.3M. The risks are believed to be strongly positively correlated. Which position is MOST accurate?

- **A** Above appetite but within tolerance on an expected basis; correlation does not change the expected sum but fattens the tail, so the loss distribution must be examined
- **B** Within appetite because every individual risk is below $1M
- **C** Beyond tolerance because correlated risks add up to more than their expected values
- **D** Within appetite because diversification lowers the expected aggregate loss

# Q12: Explanation

## Correct Answer: A

- Expected losses add: $3 \times \$400K = \$1.2M$
- \$1.2M is above appetite (\$1M) and within tolerance (\$1.3M)
- Correlation does not change the expected sum
- Correlation does increase tail (extreme-loss) exposure

## Critical Trap

Correlation affects the spread of outcomes, not the sum of expected values.

# Q13: Cost Exceeds Benefit

## Question

A control costing $400K per year would reduce expected loss by only $150K per year. Without it, residual risk exceeds appetite but is well within capacity. What should the risk practitioner recommend?

- **A** Implement the control because the risk exceeds appetite
- **B** Escalate for formal, documented acceptance by the owner with authority to exceed appetite, while exploring cheaper alternatives
- **C** Accept informally to avoid delay
- **D** Buy full insurance without further analysis

# Q13: Explanation

## Correct Answer: B

- Treatment must be economically justified
- Exceeding appetite requires explicit authority to accept
- Acceptance must be documented and reviewed
- Cheaper responses should still be explored

## Critical Trap

Exceeding appetite does not force a treatment. It forces a decision by the right authority.

# Q14: Mitigation That Backfires

## Question

After a new control is deployed, the verified residual risk is HIGHER than the original inherent risk. What is the MOST likely explanation?

- **A** An arithmetic error is the only plausible cause
- **B** The control introduced secondary risk that outweighs its benefit, so the response must be redesigned
- **C** Inherent risk was necessarily overstated
- **D** The risk has been transferred to the control owner

# Q14: Explanation

## Correct Answer: B

- Controls can create new risks (complexity, new attack surface, new dependencies)
- Secondary risk must be assessed alongside residual risk
- Net exposure, not control count, is what matters
- Redesign or replace the response

## Critical Trap

A control is not automatically net-positive.

# Q15: Recovery Dependencies

## Question

System A has an RTO of 4 hours. A's own restoration takes 2 hours and can start only after both System B and System C are available. B takes 3 hours to restore and C takes 2 hours, restored in parallel. Can A meet its RTO?

- **A** Yes, the longest single task is 3 hours
- **B** Yes, B and C run in parallel and fit inside 4 hours
- **C** No, recovery takes 7 hours
- **D** No, recovery takes 5 hours

# Q15: Explanation

## Correct Answer: D

- B and C run in parallel, so the dependency stage takes $\max(3, 2) = 3$ hours
- A then needs its own 2 hours: $3 + 2 = 5$ hours
- 5 hours exceeds the 4-hour RTO
- 7 hours would be the fully sequential case

## Critical Trap

Critical path = longest dependency chain, not the longest single task.

# Q16: Probability of Meeting RPO

## Question

The RPO is 1 hour and backups run every 4 hours. A failure occurs at a uniformly random time. What is the probability that the data loss stays within the RPO?

- A 0%
- B 25%
- C 50%
- D 75%

# Q16: Explanation

## Correct Answer: B

- Data loss equals the time since the last backup, uniform from 0 to 4 hours
- Loss is within RPO only when it is at most 1 hour
- Probability $= 1/4 = 25\%$
- Expected loss is 2 hours, twice the RPO

## Critical Trap

A backup interval longer than the RPO means the RPO is usually missed.

# Q17: MTD Consistency

## Question

A process has an RTO of 4 hours, a work recovery time (WRT) of 6 hours and an MTD of 8 hours. What is the PRIMARY problem?

- **A** Consistent because RTO (4 h) is less than MTD (8 h)
- **B** Consistent because WRT is excluded from MTD
- **C** MTD should automatically be raised to 20 hours
- **D** Inconsistent: RTO plus WRT is 10 hours, which exceeds the 8-hour MTD

# Q17: Explanation

## Correct Answer: D

- The business must be fully operating again within the MTD
- Requirement: $\text{RTO} + \text{WRT} \leq \text{MTD}$
- Here $4 + 6 = 10 > 8$
- Shorten RTO or WRT, or revalidate the MTD with the business

## Critical Trap

Meeting the RTO alone does not guarantee meeting the MTD.

# Q18: MTD from Escalating Impact

## Question

Outage losses are $10K per hour for the first 4 hours and $50K per hour afterwards. Management defines MTD as the point where cumulative loss reaches $400K. What is the MTD?

- A 11.2 hours
- B 8 hours
- C 4 hours
- D 40 hours

# Q18: Explanation

## Correct Answer: A

- First 4 hours: $4 \times \$10K = \$40K$
- Remaining threshold: $\$400K - \$40K = \$360K$
- At \$50K per hour: $360/50 = 7.2$ hours
- MTD $= 4 + 7.2 = 11.2$ hours

## Critical Trap

Impact is not linear. Piece the loss curve together before dividing.

# Q19: Treatment Selection

## Question

A risk has an 80% likelihood and a $100K impact. Treatment A costs $50K and cuts likelihood to 20%. Treatment B costs $30K and cuts impact to $40K. Applying both costs $80K. Which option has the best net benefit?

- (A) Both treatments
- (B) Treatment B only
- (C) Neither
- (D) Treatment A only

# Q19: Explanation

## Correct Answer: B

- Baseline expected loss $= 0.8 \times 100 = \$80K$
- A: loss \$20K, net benefit $= 60 - 50 = +\$10K$
- B: loss \$32K, net benefit $= 48 - 30 = +\$18K$
- Both: loss \$8K, net benefit $= 72 - 80 = -\$8K$

## Critical Trap

Benefits of overlapping treatments are not additive. The second one has diminishing value.

# Q20: Present Value of a Control

## Question

A control costs $120K upfront and reduces expected annual loss from $90K to $20K for 3 years. The discount rate is 10%. What is the approximate NPV?

A. About +$54K, so approve
B. About +$90K
C. About −$50K, so reject
D. About +$210K

# Q20: Explanation

## Correct Answer: A

- Annual benefit $= \$70K$
- PV factor for 3 years at 10% $\approx 2.487$
- PV of benefits $\approx \$174K$
- NPV $\approx 174 - 120 = +\$54K$

## Critical Trap

\$90K is the undiscounted net. \$210K is gross undiscounted benefit.

# Q21: Insurance Economics

## Question

There is a 10% annual chance of a $2M loss. Insurance covers 80% of the loss above a $200K deductible and costs $60K per year. What is the total expected annual cost with insurance?

- A $56K
- B $200K
- C $116K
- D $260K

# Q21: Explanation

## Correct Answer: C

- Retained per event $= 200K + 20\% \times 1.8M = \$560K$
- Expected retained loss $= 0.1 \times 560K = \$56K$
- Add premium: $56K + 60K = \$116K$
- Uninsured expected loss would be \$200K

## Critical Trap

Include the premium and the retained share. Insurance also leaves counterparty and coverage risk.

# Q22: Control Test Results

## Question

A control runs 250 times per year. A sample of 25 executions shows 5 deviations. The tolerable deviation rate is 5%. What is the BEST conclusion?

- (A) Effective, because the sample is only 10% of the population
- (B) Effective, because 80% of items passed
- (C) Inconclusive until all 250 executions are tested
- (D) Not effective: the 20% sample deviation rate far exceeds the 5% tolerable rate, so remediate and expand testing

# Q22: Explanation

## Correct Answer: D

- Sample deviation rate $= 5/25 = 20\%$
- 20% is four times the tolerable rate
- A passing rate of 80% is not acceptable here
- Full-population testing is not needed to see a clear failure

## Critical Trap

Compare results to the tolerable rate, not to a "mostly passed" feeling.

# Q23: Silent Indicators

## Question

Every KRI has stayed green for three consecutive years, yet the organization suffered two significant incidents. What is the MOST appropriate conclusion?

- **A** Controls are exceptionally effective
- **B** Thresholds are likely too loose or indicators insensitive, so back-test and recalibrate
- **C** Reduce monitoring frequency to save cost
- **D** Retire the KRIs

# Q23: Explanation

## Correct Answer: B

- Indicators should have moved before the incidents
- Back-test KRIs against past incidents
- Tighten thresholds and add leading indicators
- Consistent green is a warning sign, not proof of safety

## Critical Trap

A KRI that cannot detect a known failure is not doing its job.

# Q24: Poisson Annual Probability

## Question

Loss events arrive at an average rate of 0.5 per year (Poisson, independent). What is the probability of at least one event in a year?

- (A) 25%
- (B) About 39%
- (C) 50%
- (D) About 63%

# Q24: Explanation

## Correct Answer: B

- $P(\text{none}) = e^{-0.5} \approx 0.607$
- $P(\text{at least one}) \approx 0.393$
- 63% would be the answer for a rate of 1.0 per year
- 50% wrongly treats the rate as a probability

## Critical Trap

A rate is not a probability. Use $1 - e^{-\lambda}$.

# Q25: Portfolio Compromise

## Question

Ten independent systems each have a 10% annual chance of compromise. What is the probability that at least one is compromised?

- A. About 35%
- B. 100%
- C. About 65%
- D. 10%

# Q25: Explanation

## Correct Answer: C

- $P(\text{none}) = 0.9^{10} \approx 0.349$
- $P(\text{at least one}) \approx 0.651$
- 100% comes from adding $10 \times 10\%$
- 35% is the probability that none are compromised

## Critical Trap

Many small independent risks add up to a large combined risk, but not linearly.

# Q26: Exclusive Scenarios

## Question

Three mutually exclusive outcomes this year: a 10% chance of a $500K loss, a 5% chance of a $2M loss, otherwise no loss. What is the expected loss?

- (A) $150K
- (B) $2.5M
- (C) $250K
- (D) $75K

# Q26: Explanation

## Correct Answer: A

- $0.10 \times 500K = \$50K$
- $0.05 \times 2M = \$100K$
- Sum $= \$150K$
- \$2.5M adds the severities without weighting

## Critical Trap

Weight each loss by its own probability.

# Q27: Volatility of One Event

## Question

A single event has a 20% chance of causing a $1M loss and otherwise causes nothing. What is the standard deviation of the loss?

- (A) $200K
- (B) $800K
- (C) $160K
- (D) $400K

# Q27: Explanation

## Correct Answer: D

- Bernoulli loss: $\text{SD} = L\sqrt{p(1-p)}$
- $= 1M \times \sqrt{0.2 \times 0.8} = 1M \times 0.4$
- \$200K is the expected loss, not the volatility
- Rare large losses are very volatile

## Critical Trap

Expected loss is not the same as volatility.

# Q28: Value at Risk

## Question

Annual loss is normally distributed with mean \$1M and standard deviation \$400K. What is the 95% one-tailed VaR ($z = 1.645$)?

A. About \$1.66M
B. \$1.00M
C. About \$1.93M
D. \$1.40M

# Q28: Explanation

## Correct Answer: A

- $\text{VaR} = \mu + z\sigma = 1M + 1.645 \times 0.4M$
- $\approx \$1.66M$
- \$1.93M is the 99% figure ($z = 2.326$)
- \$1.00M is only the mean

## Critical Trap

VaR is a quantile of the loss distribution, not the average loss.

# Q29: Expected Shortfall

## Question

Which statement about 95% expected shortfall (ES) is correct?

- (A) It is the average loss in the worst 5% of outcomes and is never below the 95% VaR
- (B) It is the average loss across all outcomes
- (C) It is the loss level exceeded 5% of the time
- (D) It always equals VaR for normal distributions

# Q29: Explanation

## Correct Answer: A

- VaR marks where the tail starts
- ES averages the losses beyond that point
- So ES $\geq$ VaR
- ES captures tail severity that VaR ignores

## Critical Trap

VaR says where the tail begins. ES says how bad it gets.

# Q30: Monte Carlo Precision

## Question

A Monte Carlo run of 10,000 independent trials estimates an event probability of 5%. What is the approximate standard error?

- A About 0.22 percentage points
- B About 0.5 percentage points
- C About 0.05 percentage points
- D About 2.2 percentage points

# Q30: Explanation

## Correct Answer: A

- $\text{SE} = \sqrt{p(1-p)/n}$
- $= \sqrt{0.05 \times 0.95/10000} \approx 0.0022$
- So the estimate is about $5\% \pm 0.4\%$ at 95% confidence
- More trials shrink error only with the square root of $n$

## Critical Trap

Simulation output is an estimate with its own sampling error.

# Q31: Reverse Conditional

## Question

2% of systems are breached each year. Among breached systems, 80% were unpatched. 20% of all systems are unpatched. What is the probability that an unpatched system is breached?

- A 80%
- B 2%
- C 8%
- D 40%

# Q31: Explanation

## Correct Answer: C

- Bayes: $P(B \mid U) = P(U \mid B)P(B)/P(U)$
- $= 0.8 \times 0.02/0.20 = 0.08$
- 80% is the reverse conditional probability
- Unpatched systems are 4 times riskier than average

## Critical Trap

$P(A \mid B) \neq P(B \mid A)$.

# Q32: Multiplicative Sensitivity

## Question

ALE = TEF × vulnerability × loss. TEF rises 50%, vulnerability falls 40%, and loss per event rises 25%. What happens to ALE?

- A. It rises 35%
- B. It rises 10%
- C. It falls 5%
- D. It rises 12.5%

# Q32: Explanation

## Correct Answer: D

- Factors multiply: $1.5 \times 0.6 \times 1.25 = 1.125$
- Adding the percentages gives $+35\%$, which is wrong
- Order of changes does not matter
- Run one-at-a-time sensitivities to see drivers

## Critical Trap

Percent changes in multiplicative models compound. They do not add.

# Q33: Perfect Hedge

## Question

Two risks each have a loss standard deviation of \$300K and a correlation of $-1$. What is the standard deviation of the combined loss?

- (A) \$300K
- (B) \$600K
- (C) \$0
- (D) \$424K

# Q33: Explanation

## Correct Answer: C

- Var $= \sigma^2 + \sigma^2 + 2\rho\sigma^2 = 0$ when $\rho = -1$
- Gains in one exactly offset losses in the other
- Perfect negative correlation is rare in practice
- Never assume it without evidence

## Critical Trap

Diversification benefit depends entirely on correlation.

# Q34: Frequency Versus Severity

## Question

Scenario X: 4 events per year of $250K each. Scenario Y: 2 events per year of $500K each. Both are Poisson with fixed severity and the same $1M expected annual loss. Which is true?

- A Volatility is identical
- B Y is more volatile (SD about $707K versus $500K)
- C X is more volatile
- D Y has a lower expected loss

# Q34: Explanation

## Correct Answer: B

- Compound Poisson: $\text{Var} = \lambda s^2$
- X: $4 \times 250^2 \rightarrow \text{SD} = \$500K$
- Y: $2 \times 500^2 \rightarrow \text{SD} \approx \$707K$
- Fewer, larger events means a fatter tail

## Critical Trap

Equal expected loss does not mean equal risk.

# Q35: Premium Loading

## Question

Expected annual loss is $200K and an insurer charges $260K. What is the loading on expected loss?

- A 26%
- B 23%
- C 60%
- D 30%

# Q35: Explanation

## Correct Answer: D

- Loading $=$ (premium $-$ EL)/EL
- $= (260 - 200)/200 = 30\%$
- 23% wrongly divides by the premium
- Insurance usually costs more than expected loss

## Critical Trap

Measure loading against expected loss, not against the premium.

# Q36: Backing Out Inherent Risk

## Question

After controls with combined 70% effectiveness, residual exposure is $120K. What was the inherent exposure?

- A $360K
- B $400K
- C $204K
- D $171K

# Q36: Explanation

## Correct Answer: B

- Residual = Inherent $\times (1 - 0.7)$
- Inherent = $120/0.3 = \$400K$
- \$171K divides by 0.7 by mistake
- \$204K multiplies by 1.7 by mistake

## Critical Trap

Residual is a fraction of inherent, so divide by the remaining fraction.

# Q37: Return Period

## Question

A loss level has a 1-in-20-year return period. What is the probability it is exceeded at least once in 10 years?

- (A) About 40%
- (B) 50%
- (C) 5%
- (D) 10%

# Q37: Explanation

## Correct Answer: A

- Annual probability $= 5\%$
- $P(\text{none in 10 years}) = 0.95^{10} \approx 0.60$
- $P(\text{at least one}) \approx 40\%$
- 50% would require 14 years

## Critical Trap

A return period is not a schedule. Events can cluster or never occur.

# Q38: Century Event

## Question

What is the probability of at least one 1-in-100-year event in a 30-year period?

- A About 26%
- B 1%
- C 30%
- D 74%

# Q38: Explanation

## Correct Answer: A

- $P(\text{none}) = 0.99^{30} \approx 0.74$
- $P(\text{at least one}) \approx 0.26$
- 74% is the probability of none
- 30% adds probabilities linearly

## Critical Trap

Use the complement for at-least-one probabilities.

# Q39: Perpetual Benefit

## Question

A control costs $600K upfront and permanently cuts expected annual loss by $60K. The discount rate is 8%. What is the NPV?

- (A) $+\$750\text{K}$
- (B) $-\$540\text{K}$
- (C) $-\$150\text{K}$
- (D) $+\$150\text{K}$

# Q39: Explanation

## Correct Answer: D

- PV of a perpetuity $= 60/0.08 = \$750K$
- NPV $= 750 - 600 = +\$150K$
- \$750K is the benefit, not the NPV
- Payback is 10 years, but NPV is still positive

## Critical Trap

Value permanent benefits as a perpetuity, then subtract cost.

# Q40: Calibration

## Question

Experts give 90% confidence ranges, but actual values fall inside the ranges only 50% of the time. What is the diagnosis?

A. Overconfidence: ranges are too narrow, so apply calibration training
B. Normal behavior for 90% ranges
C. Underconfidence: ranges are too wide
D. Only a data quality problem

# Q40: Explanation

## Correct Answer: A

- A well-calibrated 90% range captures truth about 90% of the time
- 50% capture means ranges are far too tight
- Calibration training and feedback improve this
- Widen ranges or use structured elicitation

## Critical Trap

Most experts are overconfident. Test calibration.

# Q41: Budgeted Portfolio

## Question

Budget is $250K. Independent, additive options: A costs $50K and avoids $120K; B costs $200K and avoids $400K; C costs $20K and avoids $35K. Which portfolio maximizes net benefit?

- A and B (net $270K)
- A and C (net $85K)
- A, B and C (net $285K)
- B and C (net $215K)

# Q41: Explanation

## Correct Answer: A

- Net: A $= +70$, B $= +200$, C $= +15$
- A + B costs \$250K, net \$270K
- A + B + C costs \$270K and breaks the budget
- B + C nets only \$215K

## Critical Trap

Highest ROI alone is not the same as maximum value under a budget.

# Q42: Two-Stage Detection

## Question

Stage 1 detection catches 70% of intrusions. Whatever passes is examined by stage 2, which catches 50% of what it sees (independent of stage 1). What fraction of intrusions is missed by both?

- A 15%
- B 0%
- C 35%
- D 20%

# Q42: Explanation

## Correct Answer: A

- Missed by stage 1 = 30%
- Missed by stage 2 as well = $0.3 \times 0.5 = 15\%$
- 20% would wrongly average the catch rates
- Detection layers multiply the misses

## Critical Trap

Combined misses multiply. Catch rates do not add.

# Q43: Weighted Scenario Mean

## Question

Scenario probabilities and losses: 60% at $50K, 30% at $200K, 10% at $1M. What is the expected loss?

- A $200K
- B About $417K
- C $190K
- D $1.25M

# Q43: Explanation

## Correct Answer: C

- $0.6 \times 50 = 30$
- $0.3 \times 200 = 60$
- $0.1 \times 1000 = 100$; total $\$190K$
- \$417K is the unweighted average of the three losses

## Critical Trap

Always weight outcomes by probability.

# Q44: Multi-Year Poisson

## Question

Loss events arrive at 0.5 per year (Poisson). What is the probability of at least one event in 3 years?

- A About 22%
- B 50%
- C About 78%
- D About 85%

# Q44: Explanation

## Correct Answer: C

- Expected events in 3 years $= 1.5$
- $P(\text{none}) = e^{-1.5} \approx 0.223$
- $P(\text{at least one}) \approx 0.777$
- 22% is the probability of none

## Critical Trap

Scale the rate by time, then use the Poisson complement.

# Q45: Usable Appetite Statement

## Question

Which risk appetite statement is MOST usable for decisions?

- (A) The organization will follow industry standards
- (B) Expected annual cyber loss will not exceed $2M, and no scenario will exceed $5M at 95% confidence
- (C) The organization has a low appetite for cyber risk
- (D) The organization will manage cyber risk responsibly

# Q45: Explanation

## Correct Answer: B

- It is measurable
- It sets both an aggregate and a tail limit
- It names a confidence level
- Vague words cannot trigger escalation

## Critical Trap

If it cannot be measured, it cannot be breached.

# Q46: Beyond Tolerance

## Question

Capacity is $10M, tolerance is $6M and appetite is $4M. Aggregate exposure is now $7M. What is the BEST description?

- (A) Within appetite because it is below capacity
- (B) Beyond tolerance but within capacity: escalate and either reduce exposure or formally approve it
- (C) Capacity exceeded: stop operations
- (D) Acceptable because it is below capacity

# Q46: Explanation

## Correct Answer: B

- Ordering is appetite $<$ tolerance $<$ capacity
- \$7M exceeds tolerance (\$6M)
- It is still under capacity (\$10M)
- Tolerance breach triggers escalation and a plan

## Critical Trap

Capacity is the survival limit, not the acceptance limit.

# Q47: Central Tendency

## Question

70% of assessed risks cluster at “medium on a 5-point scale. What is the most likely problem?

- (A) The analysts are too senior
- (B) Central tendency bias: use anchored criteria and calibrate scorers
- (C) The matrix is too large
- (D) The portfolio is genuinely balanced

# Q47: Explanation

## Correct Answer: B

- Raters avoid extreme scores
- Vague scale definitions encourage hedging
- Anchored examples reduce it
- Compare scorer distributions to detect it

## Critical Trap

A suspiciously uniform distribution signals a scoring problem.

# Q48: Same Mean, Different Tail

## Question

Risk X has expected loss $100K and SD $50K. Risk Y has expected loss $100K and SD $400K. The board has low tolerance for loss volatility. Which should be prioritized?

A. Y: equal expected loss hides a far larger tail
B. Equal priority
C. X: it is more certain
D. Neither: expected losses are equal

# Q48: Explanation

## Correct Answer: A

- Y can produce losses many times its mean
- Low tolerance for volatility means tail matters
- Ranking by mean alone ignores this
- Evaluate distributions, not only point values

## Critical Trap

Expected value ranks risks only if volatility is irrelevant.

# Q49: Concentration

## Question

Twelve risks rated “medium all depend on the same vendor. What is the BEST interpretation?

- **A** Low risk, since medium is acceptable
- **B** A concentration risk to evaluate in aggregate, which may exceed appetite even though each item is medium
- **C** A procurement issue only
- **D** Twelve independent mediums, so no action

# Q49: Explanation

## Correct Answer: B

- A shared dependency creates correlated failure
- The portfolio exposure is greater than any single rating
- Aggregate by dependency, not only by item
- Registers often hide concentration

## Critical Trap

Twelve mediums with one root cause is one large risk.

# Q50: Silo Aggregation

## Question

Five departments each accept a $200K risk (each limit is $250K). All depend on one shared service. Enterprise aggregate appetite is $600K. What is the issue?

- (A) Appetite applies per department only
- (B) The exposure is only $200K because it is the same dependency
- (C) None: each is within its limit
- (D) Correlated exposure could total $1M, above enterprise appetite, so acceptances must be aggregated

# Q50: Explanation

## Correct Answer: D

- $5 \times \$200K = \$1M$ if the shared service fails
- Local limits do not guarantee enterprise limits
- Acceptance needs an enterprise view
- Escalate or treat the shared dependency

## Critical Trap

Local approval does not equal enterprise acceptance.

# Q51: Residual-Only Register

## Question

A risk register records only residual ratings. What is the main weakness?

- **A** Residual ratings are always inaccurate
- **B** Registers must list threats only
- **C** Inherent risk never matters
- **D** Hidden dependence on controls: if a control fails, the true exposure is invisible

# Q51: Explanation

## Correct Answer: D

- Inherent rating shows exposure without controls
- It shows how much each control is carrying
- Control failure analysis needs both
- Treatment prioritization needs both

## Critical Trap

Residual alone hides control dependence.

# Q52: Velocity

## Question

Two risks both score 12. Risk A can reach full impact within minutes with no warning. Risk B develops over months with clear leading indicators. Where is stronger preventive investment most needed?

- (A) Risk B, because indicators are costly
- (B) Neither: scores are equal
- (C) Risk B, because it lasts longer
- (D) Risk A, because short velocity leaves no time to respond after detection

# Q52: Explanation

## Correct Answer: D

- Velocity is time from trigger to impact
- A has no response window
- B can be managed with monitoring and response
- Equal scores can need very different strategies

## Critical Trap

Same score, different urgency.

# Q53: Rank Reversal

## Question

Impact levels are logarithmic: level 2 = \$100K and level 5 = \$100M. Risk P has likelihood level 5 (50%) and impact 2. Risk Q has likelihood level 2 (5%) and impact 5. Both score 10. What is the real difference?

- **A** Q has about 100 times the expected loss (\$5M versus \$50K)
- **B** Q has 10 times the expected loss
- **C** P has the larger expected loss
- **D** They are equal

# Q53: Explanation

## Correct Answer: A

- P: $0.5 \times 100K = \$50K$
- Q: $0.05 \times 100M = \$5M$
- Equal scores hide a 100x gap
- Multiplying ordinal levels ignores the underlying scales

## Critical Trap

Matrix scores are not expected losses.

# Q54: Appetite Test

## Question

Appetite: no scenario will exceed $5M at 95% confidence. Simulation shows a 95th percentile of $4.8M and a 99th percentile of $9M. What is the BEST conclusion?

A. Compliant, so no further discussion

B. Compliant with the statement as written, but the 99% tail deserves board attention and a review of the statement

C. Non-compliant because the 99th percentile exceeds $5M

D. Cannot be tested

# Q54: Explanation

## Correct Answer: B

- 95th percentile $4.8M is under $5M
- The statement fixed the confidence level at 95%
- The 99% tail is much larger
- Choose confidence levels deliberately

## Critical Trap

Passing a test is not the same as being safe.

# Q55: Availability Budget

## Question

A service has a 99.9% availability target measured over a 30-day month. How much downtime does it permit?

- A. About 7.2 hours
- B. About 4.3 minutes
- C. About 43 minutes
- D. About 8.8 hours

# Q55: Explanation

## Correct Answer: C

- 30 days = 43,200 minutes
- $0.1\% \times 43{,}200 = 43.2$ minutes
- 7.2 hours would be 99%
- 8.8 hours per year is the figure for 99.9% annually

## Critical Trap

Check whether the target period is monthly or yearly.

# Q56: Series Availability

## Question

Three components in series each have 99.9% availability and all must work. What is the combined availability?

- A 99.9%
- B 99.97%
- C About 99.7%
- D 99.0%

# Q56: Explanation

## Correct Answer: C

- $0.999^3 \approx 0.997$
- Series dependencies multiply
- Each added component lowers availability
- The weakest link is not the whole story

## Critical Trap

In series, availability multiplies down.

# Q57: Parallel Availability

## Question

Two independent redundant components each have 99% availability and either is sufficient. What is the combined availability?

- A 99.99%
- B 99.9%
- C 99%
- D 98%

# Q57: Explanation

## Correct Answer: A

- $1 - 0.01^2 = 0.9999$
- Both must fail for an outage
- Assumes independence and no common cause
- Shared power or software erodes the benefit

## Critical Trap

Redundancy helps only if failures are independent.

# Q58: MTBF and MTTR

## Question

A system has an MTBF of 1,000 hours and an MTTR of 4 hours. What is its steady-state availability?

- A 96.00%
- B 99.96%
- C About 99.60%
- D 99.00%

# Q58: Explanation

## Correct Answer: C

- $A = \text{MTBF}/(\text{MTBF} + \text{MTTR})$
- $= 1000/1004 \approx 0.9960$
- Repair time matters as much as failure rate
- 99.96% would need an MTTR of 0.4 hours

## Critical Trap

Availability depends on both how often and how long.

# Q59: Annual Downtime

## Question

Using MTBF 1,000 hours and MTTR 4 hours, what is the expected annual downtime?

- A 4 hours
- B About 87.6 hours
- C About 35 hours
- D About 8.8 hours

# Q59: Explanation

## Correct Answer: C

- Unavailability $= 4/1004 \approx 0.398\%$
- $8760 \times 0.00398 \approx 34.9$ hours
- Each failure costs 4 hours; there are about 8.7 failures per year
- A small unavailability still adds up

## Critical Trap

Convert percentages to hours per year before judging them.

# Q60: Replication Lag

## Question

The RPO is 5 minutes. Asynchronous replication typically lags 15 minutes. What is the conclusion?

- A RPO is not met: lag exceeds RPO, so reduce lag or use synchronous replication
- B Nothing can be concluded
- C RPO is met because RTO is unaffected
- D RPO is met because replication exists

# Q60: Explanation

## Correct Answer: A

- Data in the lag window is lost at failover
- 15 minutes is greater than 5 minutes
- Replication is not the same as meeting RPO
- Choose technology to fit the objective

## Critical Trap

Having replication does not mean meeting the RPO.

# Q61: Sequential Recovery

## Question

MTD is 24 hours. Recovery is strictly sequential: network 6 h, database 8 h, application 6 h, validation 6 h. Can the MTD be met?

- **A** No: the total is 32 hours
- **B** No: total is 26 hours, which exceeds the MTD by 2 hours
- **C** Yes: the total is 20 hours
- **D** Yes: the longest step is 8 hours

# Q61: Explanation

## Correct Answer: B

- $6 + 8 + 6 + 6 = 26$ hours
- Sequential steps add. They do not overlap
- Parallelize or pre-stage to save time
- Revisit MTD only if the business agrees

## Critical Trap

Sum sequential steps. Do not look at the longest one.

# Q62: Hot Site Economics

## Question

Downtime costs $80K per hour. A hot site costs $500K per year and cuts recovery from 24 hours to 2 hours. A disaster has a 5% annual probability. What is the conclusion?

A. Justified: avoided loss per disaster is $1.76M, which exceeds $500K

B. Not justified on cost alone: expected benefit is about $88K versus $500K

C. Break-even at $500K

D. Justified because 24 hours is too long

# Q62: Explanation

## Correct Answer: B

- Hours saved $= 22$
- Loss avoided per disaster $= 22 \times 80K = \$1.76M$
- Expected annual benefit $= 0.05 \times 1.76M = \$88K$
- Other drivers (regulation, reputation) may still justify it

## Critical Trap

Weight avoided loss by probability before comparing with annual cost.

# Q63: Recovery Capacity

## Question

Ten systems each have a 4-hour RTO. The team can restore 2 systems at a time and each wave takes 3 hours. How many systems can meet the RTO?

- A 6
- B 4
- C 10
- D 2

# Q63: Explanation

## Correct Answer: D

- Wave 1 finishes at 3 hours (2 systems)
- Wave 2 finishes at 6 hours, which is over the RTO
- Equal RTOs do not guarantee capacity
- Capacity planning must match the RTOs

## Critical Trap

RTOs are only achievable if recovery capacity exists.

# Q64: Test Scaling

## Question

A DR test restored a system in 6 hours. Data has grown 50% since, and restore time scales linearly with data. What restore time should planners expect?

A. About 9 hours
B. About 7.5 hours
C. 6 hours
D. About 12 hours

# Q64: Explanation

## Correct Answer: A

- $6 \times 1.5 = 9$ hours
- Old test results expire as data grows
- RTO of 8 hours would now fail
- Retest after material change

## Critical Trap

A passed DR test has a shelf life.

# Q65: Nightly Plus Logs

## Question

Full backups run nightly and transaction logs are shipped every 15 minutes. What RPO is realistically achievable?

- A 12 hours
- B Zero
- C About 15 minutes
- D 24 hours

# Q65: Explanation

## Correct Answer: C

- Restore the full backup, then replay logs
- Loss is bounded by the log interval
- Zero would need synchronous replication
- Log shipping itself must be monitored

## Critical Trap

RPO is set by the most frequent recovery point, not the slowest.

# Q66: Break-Even Likelihood

## Question

A $90K per year control fully removes a $600K loss. What annual likelihood makes the control break even?

- A 54%
- B 90%
- C 15%
- D 6.7%

# Q66: Explanation

## Correct Answer: C

- Break-even when $p \times 600K = 90K$
- $p = 90/600 = 15\%$
- If the likelihood is lower, the control loses money
- Compare with realistic likelihood ranges

## Critical Trap

Break-even analysis shows how wrong an estimate can be.

# Q67: ARO Reduction

## Question

A control costs $90K per year and reduces ARO from 0.3 to 0.1. SLE is $500K. What is the net annual benefit?

- (A) $-\$10K$
- (B) $+\$60K$
- (C) $+\$10K$
- (D) $+\$100K$

# Q67: Explanation

## Correct Answer: C

- Reduction $= (0.3 - 0.1) \times 500K = \$100K$
- Net $= 100 - 90 = +\$10K$
- \$100K is the gross benefit
- Thin margins make estimates critical

## Critical Trap

Net benefit subtracts the cost from the ALE reduction.

# Q68: ROSI

## Question

A control reduces ALE by $400K and costs $160K. What is the return on security investment?

- (A) 250%
- (B) 150%
- (C) 40%
- (D) 60%

# Q68: Explanation

## Correct Answer: B

- ROSI $=$ (reduction $-$ cost)/cost
- $= (400 - 160)/160 = 1.5$
- 250% divides gross benefit by cost
- 40% is cost divided by benefit

## Critical Trap

ROSI uses net benefit, not gross benefit.

# Q69: Stacked Controls

## Question

Three independent layers each remove half of the remaining risk. What fraction of inherent risk remains?

- A 12.5%
- B 25%
- C 0%
- D 50%

# Q69: Explanation

## Correct Answer: A

- $0.5^3 = 0.125$
- Each layer works on what the last one left
- Risk never reaches zero
- Assumes independence, which is rarely perfect

## Critical Trap

Layers compound multiplicatively.

# Q70: Prevent Plus Detect

## Question

Inherent: 10 events per year at $100K each. A preventive control stops 80% of events. A detective control halves the impact of remaining events. What is the residual annual loss?

- A $300K
- B $100K
- C $500K
- D $200K

# Q70: Explanation

## Correct Answer: B

- Inherent $= 10 \times 100K = \$1M$
- After prevention: $2 \times 100K = \$200K$
- After detection: $2 \times 50K = \$100K$
- \$200K counts only prevention

## Critical Trap

Preventive controls cut frequency, detective ones cut impact. Apply each to the right term.

# Q71: Avoidance Economics

## Question

A company exits a product line earning $2M profit per year to avoid $1.5M of expected annual loss. What is the likely effect?

- A. Net gain of $3.5M
- B. Net gain of $1.5M
- C. No effect
- D. Net loss of about $0.5M per year unless other costs change

# Q71: Explanation

## Correct Answer: D

- Value lost = $\$2M$
- Loss avoided = $\$1.5M$
- Net = $-\$0.5M$ per year
- Treat avoidance as a business decision, not a free action

## Critical Trap

Avoiding a risk also avoids its rewards.

# Q72: SLA Credits

## Question

A cloud SLA gives service credits capped at one month of fees ($20K). A multi-day outage would cost $500K. Does the SLA transfer the risk?

- (A) Yes: the provider bears the loss
- (B) No: credits are a small offset and the organization retains most of the loss
- (C) Yes: credits are insurance
- (D) Only for outages under one day

# Q72: Explanation

## Correct Answer: B

- Credits cap at $20K
- $480K or more stays with the organization
- Contractual remedies differ from risk transfer
- Consider insurance or resilience

## Critical Trap

An SLA is a performance promise, not an indemnity.

# Q73: Interim Exposure

## Question

A risk has a 24% annual probability of a $1M loss. A treatment takes 6 months to deploy. What is the approximate expected loss during rollout?

- A $240K
- B $1M
- C $60K
- D About $120K

# Q73: Explanation

## Correct Answer: D

- Annual expected loss $= 0.24 \times 1M = \$240K$
- Six months is half a year: $\$120K$
- The risk stays live during implementation
- Consider an interim control

## Critical Trap

Delay has a quantifiable price.

# Q74: Insurance Exclusions

## Question

A cyber policy excludes losses from known vulnerabilities left unpatched for over 30 days. The organization has many such systems. What is the implication?

- (A) The premium makes the risk acceptable
- (B) Exclusions do not matter after a claim
- (C) The risk is fully transferred
- (D) Transfer is partly void: the risk is effectively retained and must be treated by patching

# Q74: Explanation

## Correct Answer: D

- Coverage depends on policy conditions
- Unpatched systems fall outside cover
- Retained risk equals the excluded loss
- Review exclusions before relying on transfer

## Critical Trap

Insurance transfers only what the policy actually covers.

# Q75: Cost per Dollar Reduced

## Question

Control A costs $100K and reduces $150K of risk. B costs $40K and reduces $80K. C costs $200K and reduces $260K. Which is most cost-effective?

- A. C ($0.77)
- B. B ($0.50 per $1 reduced)
- C. A ($0.67)
- D. All are equal

# Q75: Explanation

## Correct Answer: B

- A: $100/150 = 0.67$
- B: $40/80 = 0.50$
- C: $200/260 = 0.77$
- Lowest cost per dollar reduced wins on efficiency

## Critical Trap

Absolute savings and efficiency can rank differently.

# Q76: Shared Hazard

## Question

Two data centers 10 km apart sit on the same flood plain and the same power grid. The design calls them geographically redundant. What is the concern?

- (A) Common-cause exposure weakens the redundancy; assess shared hazards
- (B) Floods are not a risk for data centers
- (C) None: two sites always means independence
- (D) Distance is the only factor

# Q76: Explanation

## Correct Answer: A

- Redundancy requires independent failure modes
- One flood or grid event could hit both
- Check power, network and hazard overlap
- Independence must be demonstrated

## Critical Trap

Redundancy without independence is an illusion.

# Q77: Overdue Treatment

## Question

A treatment plan is 6 months overdue and the related KRI is worsening. The risk was accepted on the assumption of timely treatment. What is the BEST action?

- **A** Extend the deadline silently
- **B** Wait for completion
- **C** Reassess residual risk now and escalate: the approved risk position no longer holds
- **D** Close the risk

# Q77: Explanation

## Correct Answer: C

- Acceptance depended on the plan
- Delay increases exposure
- The approver must know
- A new decision is required

## Critical Trap

A risk decision based on a plan expires when the plan slips.

# Q78: Control Indicator

## Question

The percentage of privileged-account reviews completed on time is BEST classified as a:

- A. Key goal indicator
- B. Key risk indicator (KRI)
- C. Key control indicator (KCI)
- D. Key performance indicator for revenue

# Q78: Explanation

## Correct Answer: C

- It shows whether a control is operating
- KRIs show changes in exposure
- Controls and risk are monitored separately
- A falling KCI may later move a KRI

## Critical Trap

KCI measures the control. KRI measures the risk.

# Q79: Zero Deviations

## Question

A control was tested with zero deviations in 59 sampled items. What can be supported statistically?

- A. 95% confidence that the rate is at most 1%
- B. Nothing can be supported
- C. About 95% confidence that the deviation rate is at most roughly 5%
- D. The deviation rate is 0%

# Q79: Explanation

## Correct Answer: C

- $P(0 \text{ of } 59 \text{ if rate} = 5\%) = 0.95^{59} \approx 0.05$
- So rate above 5% is unlikely at 95% confidence
- Zero observed does not mean zero true rate
- Tighter bounds need larger samples

## Critical Trap

Sample results bound the rate. They do not prove it.

# Q80: False Alarm Rate

## Question

A weekly KRI is approximately normal and the alert threshold is the mean plus 2 standard deviations (one-tailed probability 2.3%). About how many false alerts per year (52 weeks) should be expected when nothing has changed?

- A About 5.2
- B About 2.6
- C About 0.1
- D About 1.2

# Q80: Explanation

## Correct Answer: D

- $0.0228 \times 52 \approx 1.2$
- 2.6 would use a 5% tail
- A 3 SD threshold gives about 0.07 per year
- Thresholds must balance sensitivity and noise

## Critical Trap

Every threshold has a false-alarm rate.

# Q81: Compounding Trend

## Question

A KRI currently at 50 is growing 8% per week. The threshold is 100. About how long until it breaches?

- A About 9 weeks
- B About 25 weeks
- C About 12.5 weeks
- D About 6 weeks

# Q81: Explanation

## Correct Answer: A

- $50 \times 1.08^n = 100$
- $n = \ln 2 / \ln 1.08 \approx 9.0$
- 12.5 weeks wrongly assumes linear growth ($+4$ per week)
- Compounding shortens time to breach

## Critical Trap

Percentage growth compounds. Do not extrapolate linearly.

# Q82: Decaying Effectiveness

## Question

A control starts 90% effective. Without maintenance its effectiveness decays by 10% (relative) each quarter. What is it after 4 quarters?

- (A) About 59%
- (B) About 54%
- (C) About 81%
- (D) 50%

# Q82: Explanation

## Correct Answer: A

- $0.9 \times 0.9^4 = 0.9 \times 0.656$
- $\approx 59\%$
- 54% subtracts 36 points linearly
- Unmaintained controls drift quietly

## Critical Trap

Controls degrade unless tested and maintained.

# Q83: Self-Reported Metrics

## Question

A KRI is compiled by the same team it measures, with no validation. What is the main weakness?

- **A** The KRI is too technical
- **B** No weakness: teams know best
- **C** Reporting bias: use independent or system-sourced data and validate
- **D** The KRI is too frequent

# Q83: Explanation

## Correct Answer: C

- Teams have incentives to look good
- Unverified data cannot support escalation
- Automation reduces manual bias
- Spot checks add assurance

## Critical Trap

Whoever is measured should not control the measurement.

# Q84: Self-Review Threat

## Question

A risk practitioner designed a control and is now asked to test its operating effectiveness. What is the concern?

- **A** Self-review threat to objectivity: use an independent tester
- **B** The test will take too long
- **C** None: the designer knows the control best
- **D** The control will be too strict

# Q84: Explanation

## Correct Answer: A

- Designers tend to confirm their own work
- Independence strengthens assurance
- Walkthroughs can still involve the designer
- Testing should be done by someone else

## Critical Trap

Do not mark your own homework.

# Q85: Measurement Change

## Question

A KRI rose for three weeks after a new tool changed how events are counted. What is the BEST action?

- **A** Escalate immediately as a risk increase
- **B** Double the threshold
- **C** Validate and restate the baseline before concluding risk increased
- **D** Ignore the KRI

# Q85: Explanation

## Correct Answer: C

- The change may be an artifact of measurement
- Compare old and new methods on overlapping data
- Document the change and recalibrate
- Escalate only if the underlying risk moved

## Critical Trap

A moved number is not always a moved risk.

# Q86: CSA Bias

## Question

Control self-assessments rate 95% of controls effective, but independent tests find only 70% effective. What is the BEST response?

A. Trust the self-assessment
B. Cancel independent tests
C. Average the two and stop
D. Treat self-assessment as biased: add independent sampling and recalibrate

# Q86: Explanation

## Correct Answer: D

- Gap of 25 points indicates optimism
- Self-assessment is useful for engagement but not assurance
- Independent evidence should override
- Investigate which controls diverge

## Critical Trap

Self-assessment needs independent verification.

# Q87: Leading Indicator

## Question

Which is the BEST leading KRI for ransomware exposure?

- **A** Percentage of critical systems missing patches older than 30 days
- **B** Number of ransomware incidents last year
- **C** Total security budget
- **D** Number of audit findings closed

# Q87: Explanation

## Correct Answer: A

- It moves before an incident occurs
- Incident counts are lagging
- Budget does not measure exposure
- Closed findings measure activity, not exposure

## Critical Trap

A leading indicator changes before the loss does.

# Q88: Exception Aging

## Question

40% of risk exceptions are past their expiry date and have been auto-renewed. What does this indicate?

- (A) A permanent acceptance policy
- (B) An acceptance governance failure: require re-approval and escalate
- (C) Nothing, since exceptions are low risk
- (D) Efficient administration

# Q88: Explanation

## Correct Answer: B

- Exceptions must be time-bound
- Auto-renewal bypasses re-evaluation
- Conditions may have changed
- Old exceptions accumulate hidden risk

## Critical Trap

Exceptions are not permanent.

# Q89: Sample Size

## Question

Control A is tested with 25 items from a population of 25,000. Control B is tested with 25 items from a population of 250. Both show zero deviations. Which gives stronger statistical assurance?

- **A** A, because its population is larger
- **B** Neither provides any assurance
- **C** About the same: absolute sample size drives confidence, not the percentage of the population
- **D** B, because it covers 10% of the population

# Q89: Explanation

## Correct Answer: C

- $0.95^{25} \approx 0.28$ for both on the same logic
- Confidence depends mainly on $n$ and the deviation rate
- Coverage percentage is a poor proxy
- Larger samples tighten the bound

## Critical Trap

Percentage of population sampled is not the measure of assurance.

# Q90: Risk Statement Quality

## Question

Which is the BEST-formed risk statement?

A. Because privileged access is not reviewed, a departing administrator could exfiltrate customer data, causing regulatory fines and customer loss

B. Hackers

C. Weak access control

D. Data breach

# Q90: Explanation

## Correct Answer: A

- It states cause, event and consequence
- “Weak access control is only a cause
- “Data breach is only an event
- “Hackers is only a threat source

## Critical Trap

A risk statement must link cause, event and business consequence.

# Q91: Pre-Mortem

## Question

Which technique BEST counters overconfidence in a project plan?

- A. An annual survey
- B. Pre-mortem: assume the project has failed and explain why
- C. Benchmarking only
- D. Consensus approval

# Q91: Explanation

## Correct Answer: B

- It gives permission to voice doubts
- It surfaces risks that optimism hides
- Consensus can reinforce groupthink
- Run it before commitment

## Critical Trap

Imagine failure to find the risks success hides.

# Q92: Fourth Parties

## Question

A critical vendor relies on an undisclosed subcontractor. Assessing only the vendor misses what?

- **A** Only legal risk
- **B** Only pricing risk
- **C** Nothing: only the contract signatory matters
- **D** Concentration and flow-down risk: assess critical subcontractors and require contractual flow-down

# Q92: Explanation

## Correct Answer: D

- Subcontractors may share one provider
- Controls may not flow down
- Visibility needs contract rights
- Critical chains need mapping

## Critical Trap

Your vendor's vendor is still your risk.

# Q93: Diluted Ownership

## Question

A significant risk is owned by a committee of five managers. What is the problem?

- (A) The risk is too large
- (B) Diluted accountability: assign a single accountable owner
- (C) The committee is too small
- (D) None: shared ownership is stronger

# Q93: Explanation

## Correct Answer: B

- Everyone owns it, so no one acts
- One accountable owner can be held to deadlines
- Others can be responsible or consulted
- Ownership drives follow-through

## Critical Trap

Shared ownership often means no ownership.

# Q94: Regulatory Lead Time

## Question

A regulation passes with an 18-month effective date. When should the risk assessment of the compliance gap occur?

- (A) At 17 months
- (B) Only after a penalty
- (C) After the effective date
- (D) Now: lead time is the window to design and fund treatment

# Q94: Explanation

## Correct Answer: D

- Late assessment compresses options
- Treatment may need budget cycles
- Early view lets you plan staging
- Reassess as guidance evolves

## Critical Trap

Lead time is only useful if you start at the beginning.

# Q95: Incomplete Scenario

## Question

A scenario lists a threat and a vulnerability but no affected business objective. What is wrong?

- **A** It is incomplete: without consequence for objectives it cannot be prioritized
- **B** It is already quantified
- **C** Nothing: threat and vulnerability suffice
- **D** It is too detailed

# Q95: Explanation

## Correct Answer: A

- Risk is about effect on objectives
- Impact is required for ranking
- Link the scenario to a process and loss type
- Without it, treatment cannot be justified

## Critical Trap

No objective at stake means no risk to rank.

# Q96: Healthy Risk Culture

## Question

Which metric BEST indicates a healthy risk culture?

- **A** Number of policies published
- **B** Number of audits scheduled
- **C** Number of training slides
- **D** Trended time from detecting an incident or near-miss to escalation

# Q96: Explanation

## Correct Answer: D

- It measures behavior, not paperwork
- Short, steady times suggest people raise bad news early
- Rising times signal hesitation
- Pair with near-miss reporting rates

## Critical Trap

Culture shows up in how fast bad news travels.

# Q97: Limit Cascade

## Question

Business unit risk limits sum to $5M, but the enterprise appetite is $3M. When is this acceptable?

- (A) Never: limits must sum to the enterprise figure
- (B) Always: units are independent
- (C) Only if the CFO agrees verbally
- (D) Only if units are unlikely to reach their limits at the same time, which needs correlation analysis

# Q97: Explanation

## Correct Answer: D

- Limits can exceed appetite if peaks do not coincide
- Correlated stress can fill all limits together
- Test the cascade with stress scenarios
- Document the diversification assumption

## Critical Trap

Sum of limits versus appetite depends on correlation.

# Q98: Cascading Scenario

## Question

A cloud outage stops payments, which triggers customer attrition, which triggers covenant breaches. How should this be analyzed?

- (A) As one cascading scenario, evaluating the whole chain
- (B) As four separate small risks
- (C) Only the last consequence
- (D) Only the first event

# Q98: Explanation

## Correct Answer: A

- Dependencies create sequences
- Separate scoring understates the chain
- Model triggers and timing
- Identify where the chain can be broken

## Critical Trap

Chains of events must be assessed as chains.

# Q99: Fourth Parties

## Question

A critical vendor relies on an undisclosed subcontractor. Assessing only the vendor misses what?

- **A** Only pricing risk
- **B** Concentration and flow-down risk: assess critical subcontractors and require contractual flow-down
- **C** Only legal risk
- **D** Nothing: only the contract signatory matters

# Q99: Explanation

## Correct Answer: B

- Subcontractors may share one provider
- Controls may not flow down
- Visibility needs contract rights
- Critical chains need mapping

## Critical Trap

The vendor's vendor is still your risk.

# Q100: Anchoring

## Question

Estimators are told “last year's loss was $1M before giving their own estimates. Which bias is most likely, and what is the fix?

A. Optimism bias: reward higher estimates
B. Availability bias: remove history entirely
C. No bias: history is objective
D. Anchoring: elicit independent estimates first, then discuss

# Q100: Explanation

## Correct Answer: D

- The number pulls estimates toward it
- Independent first-round estimates reduce this
- Compare spreads before consensus
- Use history as evidence, not as a prompt

## Critical Trap

The first number heard shapes every number after it.

# Key Takeaways for Domain B

## Summary

- **Analysis:** Use complements, base rates, correlation, skew and tails. Percentages compound.
- **Evaluation:** Aggregate across silos. Ordinal scores and means can mislead.
- **BIA:** Critical path, capacity, availability math, and RTO + WRT $\leq$ MTD.
- **Treatment:** Net, discounted benefit. Layers need independence. Transfer needs coverage.
- **Monitoring:** Calibrate thresholds, verify independently, watch for decay.

# Good Luck on Your CRISC Exam!

Remember: the ISACA mindset is about
understanding why a question is asked,
not just what is technically correct.